WEEK 3 INTERNSHIP TASK

Creating Prototypes for AI Components

AI-Powered Phishing Email Detection&SOC Triage

Proof-of-concept design • decision simulation • KPIs • production-readiness analysis

Document control	Value
Task	Week 3 — Creating Prototypes for AI Components
Related work	Week 1 architecture; Week 2 data pipeline
Prototype scope	Offline sample-data simulation
Components	Validation, feature extraction, scoring, decision routing, audit metrics
Status	Conceptual prototype plan; results are illustrative, not measured production results
Prepared	October 2026

1. Executive Summary

This document proposes a practical prototype for the AI-powered phishing email detection and SOC triage solution designed in Weeks 1 and 2. It focuses on validating an email event, extracting simple risk indicators, combining transparent rule-based signals with a replaceable classifier score, assigning a risk band, and routing uncertain or high-risk cases for human review.

The proof of concept uses offline sample records rather than a live mailbox. It demonstrates component interaction and evaluation planning; it does not claim real model accuracy or production performance. A later implementation can replace the simulated classifier score with a trained model and consume validated records from the Week 2 pipeline.

2. Problem Statement and Scope

Security teams receive many emails and need to prioritize suspicious messages without treating every warning as confirmed phishing. This prototype tests a small triage flow with input validation, explainable indicators, scoring, decision routing and human review.

2.1 Included

- Read synthetic JSON/CSV email records.
- Validate required fields and normalize basic text/domain values.
- Extract urgency, URL, credential-request and sender indicators when available.
- Combine an illustrative rule score with a replaceable classifier score.
- Assign Low, Medium or High risk using example thresholds.
- Write structured results, reason codes and audit information.
- Route uncertain/high-risk cases to a simulated SOC review queue.

2.2 Excluded

- No live Gmail/Microsoft 365 connection.
- No opening links or attachments.
- No automatic deletion, blocking or replying.
- No claim that a trained model has been built or evaluated.
- No real private email content or credentials.

3. Prototype Architecture

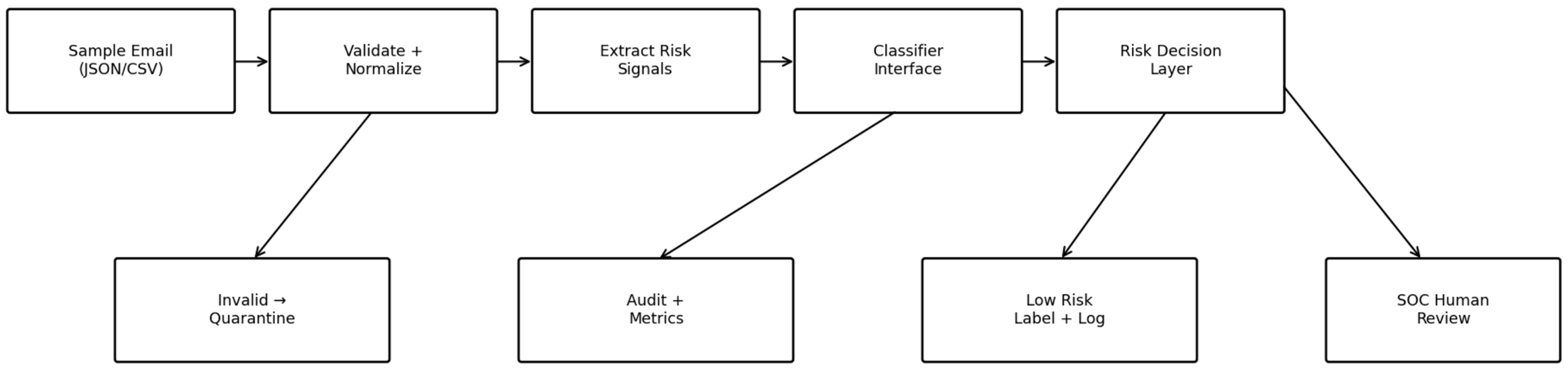


Figure 1. Offline prototype components and outputs.

Component	Responsibility	Prototype approach
Sample input	Provide repeatable test emails	Synthetic JSON/CSV
Preprocessor	Validate and normalize	Python functions/schema checks
Feature extraction	Find simple risk signals	Transparent URL/text checks
Classifier interface	Represent inference boundary	Simulated score, later replace with trained model
Decision layer	Combine signals and assign risk	Documented example thresholds
Review queue	Expose cases needing judgment	Local output list/CSV
Audit/metrics	Track results and errors	JSON/CSV logs with run ID

4. Prototype Methodology

Step 1 — Prepare sample records

Create synthetic examples: normal business email, legitimate urgent email, suspicious login request, suspicious URL, missing fields, and duplicate event.

Step 2 — Validate input

Check event ID, sender, subject, timestamp, and body/body reference. Invalid records are quarantined with a reason.

Step 3 — Extract indicators

Identify urgency language, credential requests, URL presence/count, sender-domain mismatch, and supplied authentication results. Never open links.

Step 4 — Score the record

Transparent rules generate a rule score. A classifier score is simulated for interface testing and is not a real model result.

Step 5 — Triage

Example thresholds assign Low, Medium or High. Thresholds require calibration on representative labeled data. High-risk/ambiguous cases go to human review.

Step 6 — Log output

Record event ID, features, component scores, risk band, reason codes, processing time, component versions, and review status. Avoid logging full sensitive bodies.

5. Decision Flow

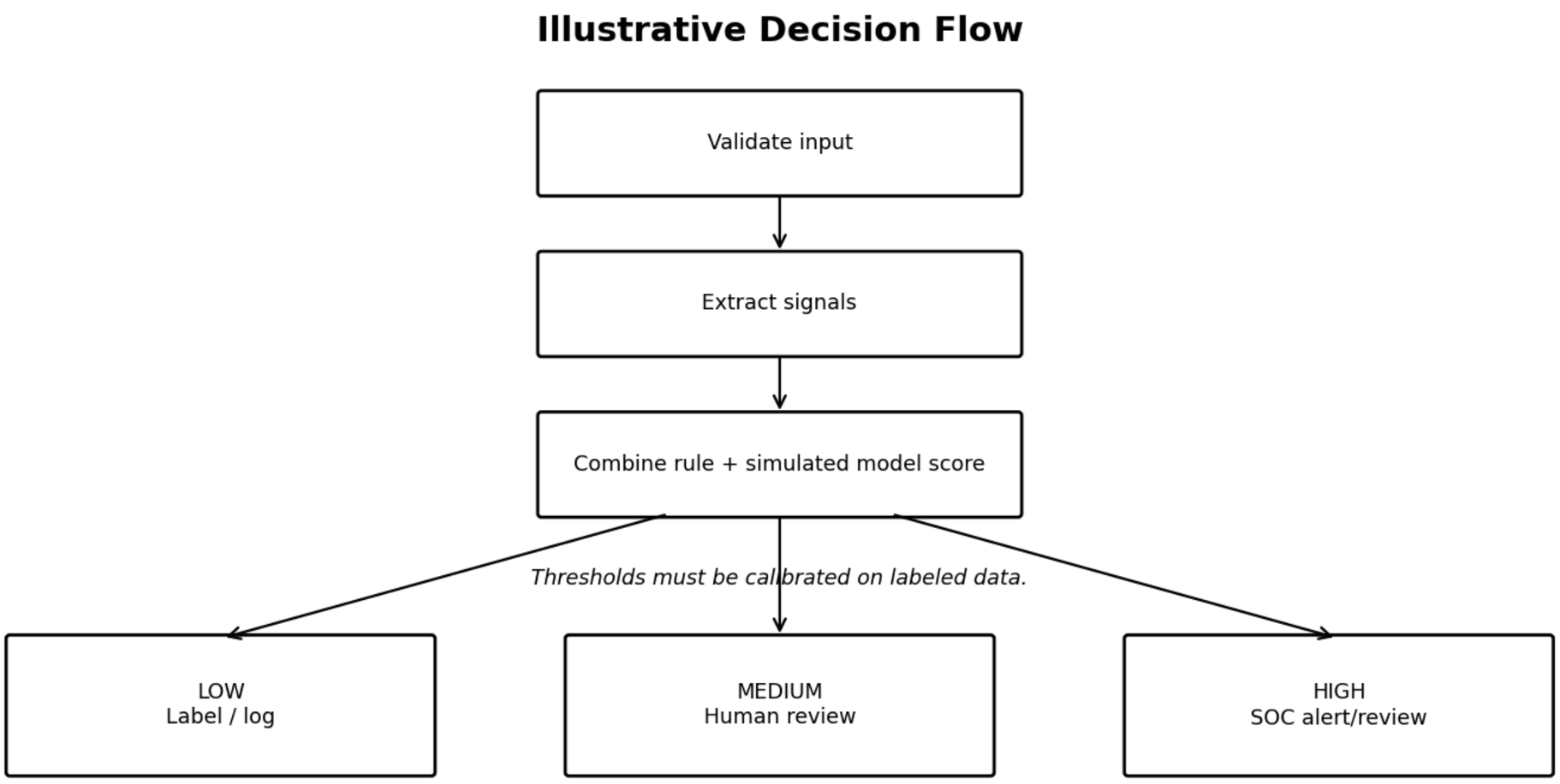


Figure 2. Example triage flow; thresholds are illustrative.

6. Example Simulation Cases

Case	Signals	Expected illustrative outcome	Reason

A — Routine meeting update	No suspicious URL or credential request	LOW	No strong risk indicators
B — Urgent account warning	Urgency language + login URL	MEDIUM	Needs review; urgency alone is not proof
C — Credential request	Password/OTP request + suspicious URL	HIGH	Multiple independent indicators
D — Invalid record	Missing event ID or timestamp	REJECT / QUARANTINE	Required fields missing
E — Duplicate delivery	Repeated event ID	DEDUPLICATED	Avoid duplicate cases

These are expected scenario outcomes, not measured experimental results. Real results depend on the data, implementation, model and thresholds.

7. Prototype Output Schema

Field	Purpose
event_id	Unique processing key
validation_status	PASS/WARN/FAIL
features	URL count, urgency and credential flags
rule_score	Rule-derived score
classifier_score	Simulated until a trained model is connected
risk_band	LOW/MEDIUM/HIGH
reason_codes	Short explanation
review_required	Whether analyst review is needed
component_version	Reproducibility
processing_ms	Runtime measured when implemented
analyst_disposition	Pending/confirmed phishing/false positive

8. KPIs and Evaluation Plan

KPI	Definition / measurement

Precision	TP / (TP + FP): how many flagged emails are truly phishing
Recall	TP / (TP + FN): how many phishing emails are detected
F1 score	2 × precision × recall / (precision + recall)
False-positive rate	FP / (FP + TN)
Processing latency	Per-event runtime; report p50 and p95 after running
Invalid-input handling	Invalid records correctly quarantined / all invalid records
Duplicate protection	Repeated events do not create duplicate cases
Human-review load	Count and percentage routed to analyst
Traceability	Outputs link to source event and component versions

Do not report accuracy or latency values until the prototype is run on a documented test dataset and environment. Use a separate labeled test set and include difficult legitimate examples.

9. Performance Analysis and Improvements

Expected strengths: modularity, repeatability, explainable rule signals, safe offline testing, and a clear interface for a future ML model. Validation and quarantine reduce the risk that malformed records produce misleading outputs.

Expected limitations: keyword rules can miss new phishing styles and may flag legitimate urgent messages. Synthetic data does not represent all real email. A simulated classifier score cannot establish model performance. Live provider integrations and production load have not been benchmarked.

Area	Challenge	Improvement
Rules	Easy to evade; false alarms	Add labeled data and sender-authentication signals
Model	No trained model evaluated	Train baseline and test on held-out data
Class imbalance	Accuracy can be misleading	Report precision, recall, F1 and PR-AUC
Latency	External enrichment can be slow	Timeouts, caching, asynchronous enrichment
Explainability	Single score is hard to trust	Return reason codes and evidence

Privacy	Email contains sensitive data	Minimize, encrypt, restrict and define retention
Drift	Attack patterns change	Monitor drift and reevaluate regularly

10. Integration with Weeks 1 and 2

Week	Connection
Week 1 — Architecture Blueprint	Defines system components; this prototype tests validation, scoring, decision and review boundaries.
Week 2 — Data Pipeline Strategy	Supplies canonical validated records; prototype consumes these rather than raw provider payloads.
Week 3 — Prototype	Demonstrates a small end-to-end path and defines evaluation before production.

Recommended interface: Week 2 curated record is the input contract; the prototype emits a structured triage result and audit record. Keep components replaceable behind simple functions or API boundaries.

11. Challenges Before Production

- Acquire a lawful, representative, labeled dataset and document label quality.
- Train and evaluate a real baseline model; do not rely on simulated scores.
- Calibrate thresholds for the desired false-positive/false-negative trade-off.
- Add secure provider authentication, secrets management and retention controls.
- Load-test throughput, p95 latency, queue backlog and outage recovery.
- Treat email text as untrusted input and defend against prompt injection.
- Require human approval for consequential actions during early deployment.
- Version datasets, features, rules, prompts and models.
- Add monitoring, rollback, incident response and periodic evaluation.

12. Responsible AI and Security

- Never execute instructions found inside email text.
- Do not open links or attachments in this offline prototype.
- Keep credentials and API keys out of code and documents.
- Use synthetic or approved sanitized data.
- Send only necessary information to AI services.
- Validate structured model output before using it.
- Keep human review for high-risk or ambiguous cases.
- Log decisions without unnecessarily storing sensitive content.

13. Public Research References

- **NIST AI Risk Management Framework —** https://www.nist.gov/itl/ai-risk-management-framework
- **NIST AI RMF Playbook —** https://airc.nist.gov/AI_RMF_Knowledge_Base/Playbook
- **scikit-learn — Model evaluation —** https://scikit-learn.org/stable/modules/model_evaluation.html
- **scikit-learn — Classification metrics —** https://scikit-learn.org/stable/modules/generated/sklearn.metrics.classification_report.html
- **Google Cloud — MLOps continuous delivery and automation —** https://cloud.google.com/architecture/mlops-continuous-delivery-and-automation-pipelines-in-machine-learning
- **OWASP — Top 10 for Large Language Model Applications —** https://owasp.org/www-project-top-10-for-large-language-model-applications/

14. Conclusion

This prototype plan demonstrates a feasible first slice of the phishing detection and SOC triage system. It connects validated input, transparent feature checks, a replaceable classifier interface, decision routing, human review and audit metrics. Next, implement the offline simulation, run it on labeled test data, report measured KPIs, and progress through controlled integration and production-readiness testing.

Appendix — Submission Checklist

- Prototype component and scope defined.
- Architecture and decision diagrams included.
- Methodology and example cases documented.
- Output schema and KPIs included.
- Performance limitations and improvements explained.
- Week 1 and Week 2 integration described.
- Production, security and privacy risks covered.
- Public references included.
- DOCX prepared for submission.